



Faculty of Engineering, Mathematics and Science

School of Computer Science & Statistics

EXAM SOLUTION NOTES

MSc in Computer Science Hilary Term 2026 Year 1

Security of Networks and Distributed Systems
CS7NS5/CSU44032

dd MMM 2026

Location

Time (2 hours)

Dr. Stephen Farrell

Instructions to Candidates:

Attempt **three** questions. All questions carry equal marks (40 each).

You may not start this examination until you are instructed to do so by the invigilator.

Materials Permitted for this examination:

N/A

Exam questions are in **bold, like this**. Solution notes are in non-bold Courier New, like this.

Question 1

An email newsletter distribution company (let's call them "distro") send bulk emails on behalf of their customers, generally to lists of email addresses supplied by those customers. As the customers manage the lists of email addresses, the customers are the GDPR data controllers for those lists. Newsletter content can be supplied by the customer or generated on their behalf as a (paid-for) editorial service from "distro." Since LLM tooling has become widely available, more customers are generating their own newsletter content using such tools. Even when a customer prepares newsletter content, "distro" still currently need to modify that content, so that e.g. plain content URLs are turned into tracking URLs that feed into the telemetry "distro" make available to their customers.

"Distro" however live or die based on the deliverability of their email, which is non-trivial when sending bulk email. Deliverability is also mostly out of the sender's control and is ultimately controlled by email recipients classifying the emails as spam or ham, and by mailbox providers such as Gmail or Microsoft.

Given the increasing use of LLM tools by "distro" customers, the company are becoming more concerned about how that might create risks for their business and so they engage you to carry out a risk analysis for them, to consider the impact of LLMs and other technical ecosystem developments and how those might impinge on the "distro" business model.

(a) Describe the process you would use to carry out this task (note: this part of the question asks about process, not the specific risks associated with the new environment).

[15 marks]

The student should describe a process of identifying assets (in this case including email sending reputation) and risks, classifying them in terms of impact and probability of occurrence, e.g. with High/Medium/Low scores for each, and assigning an overall (partial) order to the list. Normally, one then iterates, designing a mitigation for the most important item on the list, and then re-doing the analysis as necessary (since one mitigation may affect the probability of other risks or may introduce other risks). In practice, the process terminates when the available effort is expended. In this case, using LLMs to do bulk-mail sending isn't well-established (yet!) so we'll allow some flexibility if the answer is sane. Any answer that captures most of this is fine, as are descriptions of equally good alternative processes.

Up to 10 marks for describing a reasonable process, 5 more for overall goodness.

(b) Describe three significant technical risks affecting the “distro” business model, including their potential impact and likelihood of occurrence, and outline the related mitigations you would recommend that “distro” ought consider.

[15 marks]

Up to 4 marks per risk, with 3 for overall goodness. Risks here are fairly obvious, but examples include:

- Customers might move to using an LLM to create their own email bulk sending system (the main risk, though perhaps less probable)
- Customers will likely use distro’s editorial services less is a non-technical risk but ok to discuss
- Customers LLM’s may generate newsletter content that damages their own and/or “distro”’s reputation, that could lead to disputes between distro and customers
- Customers LLM’s may generate newsletter content that includes prompt injection
- Customers LLM’s might generate bad email lists that degrade distro’s sending reputation or that are undeliverable
- Customers LLMs may produce content with sensitive data that could affect distro’s reputation

(c) Any genuine bulk emailed newsletter will include an “unsubscribe” link allowing the email recipient to opt-out of future versions of the newsletter. Good distribution companies (like “distro”) will also offer the option of opting-out of all future newsletters and other marketing communications, across all “distro” customers. Who is the GDPR data controller for the list of email addresses that have opted out of all communication? Say why that is the case, and describe two consequences that flow from that for “distro” and their customers.

[10 marks]

5 marks per risk for the right answer and why (distro are the data controller for that list, ‘cause they’re the only option), with 3 identifying related issues, e.g. whether distro can tell customers that someone is on that list (probably no), handling subject access requests, handling RTBF etc.

Question 2

(a) For any real Internet key exchange protocol (e.g. TLS, IPsec, or Kerberos) describe the key management and application data protection aspects of the protocol in detail. Describe how a library developer, for example the OpenSSL project for the TLS protocol, might test their implementation.

Your answer may describe any widely used version of your chosen protocol, but for TLS, you must explicitly state which version you are describing.

[25 marks]

Marks-from-15 for a good description of the scheme, with e.g. the TLS handshake and application layer properly described. 5 marks for describing possible test setups well, 5 for additional goodness (e.g. covering optional TLS extensions/tickets etc).

Historically, 95+% of students will very reasonably choose TLS and those that do not tend to be well clued-in about whatever else they pick (usually IPsec or Kerberos 'cause they've done some work on that)

(b) Describe how cryptographic algorithms intended to withstand attacks using a Cryptographically Relevant Quantum Compute (CRQC) could affect deployments of your chosen protocol. Aside from what "could" happen - what "should" be done in the next 3-5 years? (And why.)

[10 marks]

Marks from 6 for good points about KEMs, and from 4 for signatures (as those are less pressing). For TLS, the sizes of KEM artefacts is annoying but bearable and hybrid KEMs are sensible yet also practical, even including the fallback of sending both x25519 and x25519mlkem768 key shares in client hello. If even larger KEM artefacts became desirable, HRR could save the day. It's already time to deploy hybrid and one should not deploy non-hybrid KEMs, though some student could make an argument for non-hybrids (CNSA support) that would get marks. Performance is fine here.

Signatures are quite problematic - for TLS we current need ~3 signatures and two public keys which is already a lot; PQ sig algs make that worse, and obvious hybrid ideas may well result in too many failed connections. (And also need a new PKI.) Probably best to deploy nothing right now but continue experiments.

(c) Describe one realistic way in which some load-balancing technique can be used as a way to improve the scalability of a deployment of your chosen protocol.

[5 marks]

Straight marks from 5 for anything reasonable, could be DNS based, based on haproxy or similar, or even anycast. More marks for more realistic detail.

Question 3

You are tasked to design a new web-based system for handling legal documents for the Irish courts system. The system must allow lawyers and judges involved in cases to file and access documents as cases progress. The public should also be able to access filings and evaluate their authenticity (as filed documents) without authenticating. Typical filings might include evidence statements, pleadings, and decisions. Some non-lawyers will also be able to login to the system, for example, legal secretaries and court staff who can file documents on behalf of relevant lawyers or judges. It is critical that only appropriately authorised users can modify the state of the system, and that all filings retrieved from the system can be demonstrated to have been validly filed. You can assume there are about 5,000 users who can login to the system and that it processes some hundreds of thousands of filings annually. For parts (a) and (b) of your answer you may assume that all filings are public information and immutable.

Notes: 1) If you are not familiar with the Irish legal system, it is entirely fine to base your answer on some other legal system with which you are more familiar. 2) Don't get bogged down in too much detail - good descriptions of the requirements and most important mechanisms proposed are what's important in your answer. 3) Pay attention to the marks for each section of your answer.

Lastly, you might consider how this system could have similarities with how Certificate Transparency is used as part of the WebPKI.

(a) Outline a design for the overall system (include role descriptions and diagrams as appropriate), and state the security and privacy requirements the overall system should meet. Note that this part of your answer should only discuss security and privacy requirements and not describe specific mechanisms to meet those requirements.

[20 marks]

8 marks for overall design which is mostly obvious, but paying attention to role and audit requirements (e.g. with CT-like auditing and visibility) gets more; 8 marks for more obvious requirements identified, with more for including e.g. admin user roles. 4 more for overall goodness

one good requirement that's maybe non-obvious: as a national-scale system, the specs should be public (and subject to public review) and some open-source implementations (esp for the public side) would be very good

As usual some students will mix up requirements & implementation/mechanisms (i.e. parts (a) & (b)) but I'll be lenient on that.

(b) Describe, in detail, the most important security and privacy mechanisms you propose for the system to meet requirements from part (a).

[15 marks]

Marks from 10 for workable and audit-friendly answers, or, for good justification of less audit-friendly answers, with 5 more for inclusion of less obvious things. Less obvious things might include:

- details of a CT-like append-only scheme – doesn't need to include details of merkle-trees, but excellent if they do
- distributed admin (e.g. law firm can delegate who's on which cases)
- scalability of public-facing parts
- masking some personal identifiers, e.g. of legal-secretaries
- anti-DoS/resiliency mechanisms
- consideration of long-lived archival nature of the data store
- support for assistive tech or Irish language (or other) translations of documents

(c) Some legal cases involve information that is not public, for example, cases involving children or where the court orders that information not be published until after the case has been decided. How could you extend your system to support such non-public information that needs to be verifiable and available to some users, but that won't become public until later, if ever?

[5 marks]

Straight marks from 5. The basic idea would be to add encrypted versions of the documents to the data store (and maybe have associated key-witness values) and have a parallel data store for keys that are later added to the public data store when decryption is to be supported (and also publish the plaintext document). There may be associated data as to why data wasn't initially public. There may be an aspect of selective field confidentiality but it'd be ok to not get into that level of detail.

Question 4

(a) Describe the privacy issues that arise with the Domain Name System (DNS), and usable mitigations for those, including those that might affect registrants, as well as those arising from use of the DNS for querying resource records. Where relevant, include discussion of the pros and cons of various deployment options, such as the use of public recursive resolvers.

[20 marks]

4 marks for describing registrant data access (whois etc.); 8 marks for describing privacy issues well (act of accessing name from IP at time, sets of qnames being identifying etc.); 4 marks for correctly stating the effects of DoT/DoH (with maybe a bonus if done really well, e.g. noting that there are displacement issues at play); 4 marks for overall goodness. Noting pros/cons in each case makes for better marks.

(b) Describe the ways in which PKIs, and in particular the Web PKI, interact with the DNS and how those impact on the security and privacy of the CAs, relying-parties and subscribers involved.

[15 marks]

Marks-from-6 for a reasonable description of overall Web-PKI/DNS interdependencies, more if they include e.g. use of multiple vantage points in ACME challenge checking and hosting problems with ACME TLS-SNI challenges. Specific DNS attacks (up to 3 marks each):

- DoS (or censorship) of authoritatives to prevent access, or more subtly, cert renewal
- Registrar attacks for domain take-over, followed by cert issuance, possibly coupled with active TLS MITM
- Localised DNS spoofing (e.g. within a country) in order to route traffic via an attacker controlled n/w for traffic analysis/censorship
- DNS attacks that aim to force use of ACME services that are attacker controlled
- (V. subtle, lots of marks if noted, even if not directly affecting Web-PKI): delay HTTPS RR answers versus A/AAAA answers and make HTTPS TTL small, sufficient that browser connections fail to make use of ECH as the

ECHConfig only arrives after the TLS connection has started

(c) What is the most practical and impactful way in which you could abuse the DNS for fun or profit (or to be a nuisance)? How would you execute your evil plan?

[5 marks]

Straight marks from 5 for sneakiness and practicality/impact and a way to execute. Could be as simple as a fake AP in a coffee shop, or registering a confusable